DVWA Security Testing

Portfolio Report Addendum: Scope, Findings & Remediation

Prepared by: Masum Ansari

Assessment type: Educational, controlled-lab walkthrough

Target: Damn Vulnerable Web Application (DVWA)

Evidence basis: The accompanying 44-page walkthrough and its screenshots. No independent retesting was performed while preparing this addendum.

Important: DVWA is intentionally vulnerable. The results below describe the lab demonstrations documented in the source report and are not claims about a real production application.

1. Executive Summary

The source walkthrough documents practice against DVWA across several common web application vulnerability classes. The report includes screenshots and examples at different DVWA security levels, primarily using a browser, Burp Suite, and sqlmap. This addendum organizes those topics into a portfolio-friendly summary and provides defensive recommendations.

The original report is best presented as a learning lab rather than a professional client penetration test. It does not establish a real-world risk rating, prove impact outside the lab, or include independent validation of every step. Findings are therefore labelled as **Demonstrated in the documented lab**, not as independently verified production findings.

2. Scope and Methodology

In scope: The DVWA features covered in the source PDF: brute force, OS command injection, file inclusion, blind SQL injection, SQL injection, file upload, CSRF, stored XSS, and reflected XSS.

Method represented in the source: Manual interaction with DVWA, source-code inspection, HTTP request inspection/modification with Burp Suite, and sqlmap use for SQL injection examples. Screenshots are used as supporting evidence.

Out of scope: Any public or third-party target, production systems, independent retesting, formal exploitability validation beyond the screenshots, and quantitative business-impact assessment.

3. Findings Summary

Finding	Lab evidence in source report	Suggested priority*
Brute-force weakness	Pages 2–5 show dictionary-based login testing at multiple DVWA security levels.	Medium–High
OS command injection	Pages 6–9 show command separators and source-code/filter review.	High
File inclusion / path traversal	Pages 10–13 show path-based file access attempts and URI-scheme examples.	High
Blind SQL injection	Pages 14–17 show sqlmap requests and database/table enumeration examples.	High
SQL injection	Pages 18–22 show source-code review and SQL injection examples.	High
Unsafe file upload	Pages 23–29 describe upload validation tests and changing request metadata/file names.	High
CSRF	Pages 30–36 show password-change request inspection and referrer-based checks.	Medium–High
Stored XSS	Pages 37–40 show stored input leading to browser alert execution.	Medium–High
Reflected XSS	Pages 41–44 show reflected input and filter-bypass examples.	Medium–High

*Priorities are indicative educational guidance only, not measured CVSS ratings. Production severity depends on exploitability, exposure, affected data, privileges, and business context.

4. Remediation Guidance

Brute force

Apply per-account and per-source rate limits; progressive delays; MFA; breached-password checks; secure account recovery; and monitoring for repeated failures. Avoid relying on IP blocking alone.

OS command injection

Avoid shell invocation where possible. Use safe APIs and argument arrays, strict allowlists for accepted values, least-privilege service accounts, and server-side validation. Output escaping alone is not a sufficient fix.

File inclusion / path traversal

Use fixed server-side identifiers mapped to permitted files. Canonicalize and validate paths against an allowlisted base directory; deny traversal and unnecessary URI wrappers; restrict filesystem permissions.

SQL injection

Use parameterized queries/prepared statements for all data values. Apply least-privilege database permissions and safe error handling. Input validation is additional defence, not a substitute for parameterization.

Unsafe file upload

Allowlist required file types; validate file signatures and content; generate server-side filenames; enforce size limits; store uploads outside the web root or on isolated storage; disable execution; and scan where appropriate.

CSRF

Use unpredictable anti-CSRF tokens for state-changing requests, SameSite cookies, origin validation as defence-in-depth, and POST/appropriate methods for state changes. Do not rely on Referer checks alone.

Stored and reflected XSS

Contextually encode output, use safe DOM APIs, validate input as appropriate, and avoid inserting untrusted content as HTML. Deploy a suitable Content Security Policy as an additional layer, not as the primary fix.

5. Limitations and Quality Notes

• This addendum is based on the source PDF and screenshots; it does not claim that the lab was rerun or that all results were independently reproduced.

• The original PDF uses local addresses and session-cookie examples. Confirm that no valid secrets, real credentials, personal data, or externally reachable target details are included before publishing.

• The source report has spelling/grammar issues and some explanations that should be corrected. In particular, pages 23–29 discuss file upload while the section heading says “File Inclusion.”

• Some payloads and tool interfaces may be version-specific. Re-verify commands and screenshots in your own current local lab before claiming reproducibility.

• The original document contains exploit examples. Publish only with a clear authorized-lab disclaimer and never test these examples on systems without explicit permission.

6. Conclusion

The walkthrough demonstrates exposure to common web application testing techniques and security tools. With this addendum, it is easier to navigate and more balanced because it includes defensive guidance and transparent limitations. For a stronger portfolio, the next step is to proofread the original walkthrough, add consistent evidence captions, and validate each lab step before presenting it as reproducible work.

Responsible-use statement: This material is intended for education and authorized security testing in a controlled environment only.